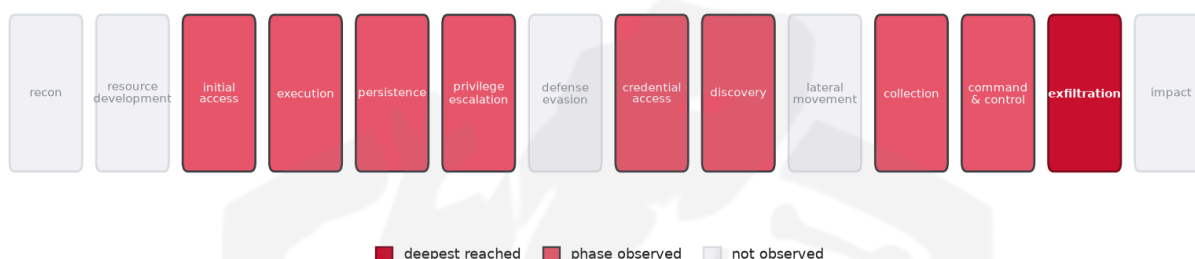


THREAT REPORT: KIMSUKY CAMPAIGN LEVERAGING XENORAT

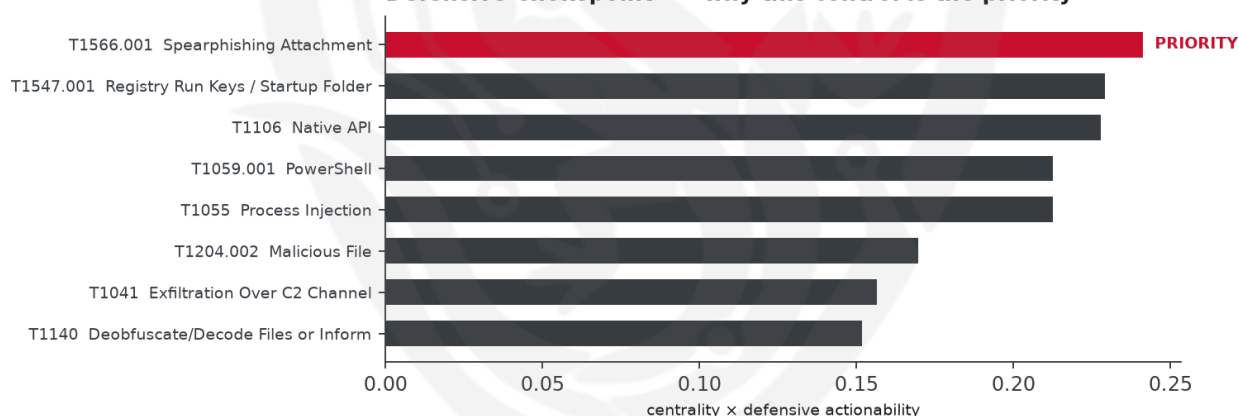
Visual Summary

Kill-Chain Reach — Critical (deepest phase reached: exfiltration)



How far down the attack chain this campaign reached; deepest phase in crimson.

Defensive Chokepoint — why this control is the priority



The control that most disrupts the attack (priority in crimson).

Summary

The source attributes this activity to Kimsuky. The group is employing the XenoRAT malware family in its operations. The campaign's targeted geography and sectors are not specified in the source. Priority should be given to sandboxing and detonating email attachments, blocking executable or script archive contents at the gateway, stripping Mark-of-the-Web bypass, and encouraging users to report phishing attempts.

Threat Overview

Kimsuky is the observed threat actor, utilizing the XenoRAT malware family. No specific CVE is identified for exploitation. Victimology details such as targeted country or sector are not provided.

Attack Chain and Priority Control

The observed activity begins with a spearphishing attachment (T1566.001) that delivers a malicious file (T1204.002). Once executed, the payload leverages native Windows mechanisms such as Rundll32 (T1218.011), Mshta (T1218.005), PowerShell (T1059.001), and the Windows command shell (T1059.003) to run. Execution is further supported by scheduled tasks (T1053.005), registry run keys/startup folder (T1547.001), and process injection (T1055). The malware performs system information discovery (T1082), keylogging (T1056.001), and data collection from the local system (T1005). Collected data is encoded (T1132.001), obfuscated (T1027, T1140), and exfiltrated over the C2 channel (T1041).

Priority technique: T1566.001 Spearphishing Attachment

Concrete control: Sandbox and detonate email attachments; block executable/script archive contents at the gateway; strip mark-of-the-web bypass; user report-phish button.

Infrastructure and Corroboration

The enrichment data did not identify any hosting providers or autonomous system numbers associated with the malicious infrastructure (n/a). AbuseIPDB reported no indicators with a confidence level of 80 % or higher, and abuse.ch did not corroborate additional malware families.

Technical Appendix

Ground-truth telemetry from the source pulse; analytical scores are secondary and clearly labelled.

Observed Techniques (ATT&CK, expert-tagged by source)

- T1053.005 Scheduled Task
- T1218.011 Rundll32
- T1132.001 Standard Encoding
- T1056.001 Keylogging
- T1204.002 Malicious File
- T1566.001 Spearphishing Attachment
- T1082 System Information Discovery
- T1106 Native API
- T1005 Data from Local System
- T1140 Deobfuscate/Decode Files or Information
- T1055 Process Injection
- T1218.005 Mshta
- T1041 Exfiltration Over C2 Channel
- T1059.001 PowerShell
- T1547.001 Registry Run Keys / Startup Folder
- T1027 Obfuscated Files or Information
- T1059.003 Windows Command Shell
- T1071.001 Web Protocols

- T1574.002 Hijack Execution Flow
- T1105 Ingress Tool Transfer

Analytical Scores

- Priority technique (graph chokepoint): T1566.001 Spearphishing Attachment (centrality 0.2413).
- Operational risk: Critical (score 0.968, reaches exfiltration).

Behavioral Signature Cluster

- Method: technique-overlap cosine vs 170 MITRE ATT&CK Groups (top overlap 0.5909; reference threshold $\tau = 0.6$).
- These are behavioural resemblances for defensive playbook cross-referencing, not an identity assessment. Where the source pulse names an actor, that attribution is authoritative; the overlaps below neither confirm nor contest it.

Nearest historical profiles by behavioural overlap (resemblance only):

Historical Profile	Behavioural Overlap
APT19	0.5909
TA551	0.5808
Confucius	0.5615
Rancor	0.5571
APT37	0.5285

Enrichment Signal

- Highest AbuseIPDB confidence among IOCs: 0%.

Indicators of Compromise (defanged — non-clickable)

The network and file indicators observed in this activity are listed below for blocklisting:

Type	Indicator
Hash	0080cd81db3244b8ba157ffabc1d30fe
Hash	00f7955410783941d527afc12908556a
Hash	029628bd99899c750d5537ee637fe3ca
Hash	03a830875abc607aa30a621eb84697c8
Hash	09bd2f48fcd29a0ed46b099c4d939024

Flame Cell // Adversary Pivot [BETA]

BETA. A hypothetical tabletop projection, anchored to documented ATT&CK behaviour and technique co-occurrence across 170 tracked groups. It is not a prediction; treat it as a war-game prompt and review before acting. Spot a pivot that looks wrong? norbert@salacti.com

- **Control applied:** T1566.001 Spearphishing Attachment (initial-access)
- **Observed here:** T1566.001 Spearphishing Attachment was the initial-access control point here; the pivot escalates to execution, drawn from Kimsuky's own documented ATT&CK repertoire.
- **Projected pivot:** T1559 Inter-Process Communication (execution)
- **Basis:** documented in Kimsuky's own ATT&CK repertoire, and disproportionately paired with Spearphishing Attachment across tracked groups (lift 1.6, ~1.6x base rate). Their move, not a generic one.

With T1566.001 Spearphishing Attachment blocked, Kimsuky could preserve the same objective by pivoting to T1559 Inter-Process Communication, a technique from Kimsuky's documented repertoire. Defensive countermeasure: Apply the specific MITRE ATT&CK mitigation for this technique; add host/network detections and least-privilege controls around it.

- **Defensive countermeasure:** Apply the specific MITRE ATT&CK mitigation for this technique; add host/network detections and least-privilege controls around it.